

13장 이 피처는 누구 것이고, 누가 봐도 되는가

12주차 · 피처 거버넌스

8장에서 피처(feature)를 한곳에 정의하고 훈련과 서빙이 같은 곳에서 읽게 만들었다. 그때는 피처가 사실상 하나였고 쓰는 쪽도 하나였다. 여러 부서와 여러 모델이 같은 피처를 나눠 쓰기 시작하면 기술 구조만으로는 답할 수 없는 질문이 생긴다 — 이 값은 정확히 무엇이고 누가 책임지는가, 누가 언제 무슨 목적으로 봤는가, 정의가 바뀌면 누가 영향을 받는가.

이 장은 그 세 질문에 기록과 통제로 답하는 **피처 거버넌스(governance)**를 다룬다. 실습은 8장이 남긴 피처 정의와 7장 확정 집계를 입력으로 카탈로그·접근 로그·품질 규칙·변경 이력을 직접 만든다.

1. 오늘의 질문

- 피처에 소유자와 사용 목적을 적어 두지 않으면 나중에 무엇을 못 하게 될까?
- 접근을 기록하는 것과 접근을 막는 것은 어떻게 다를까?
- 값이 계약을 어긴 것과 값의 분포가 이동한 것은 왜 다르게 처리해야 할까?
- 피처 정의를 바꾸면 누구에게 알려야 하는지 어떻게 알까?

2. 도서관 대출대로 보는 이 장

이 장의 네 장치는 도서관 대출대에서 벌어지는 일에 하나씩 대응한다.

도서관	피처 거버넌스
장서 목록 — 무슨 책이 있고 누가 관리하는가	카탈로그(catalog) — 어떤 피처가 있고 정의·소유자·목적이 무엇인가
목록에 없는 책은 대출 신청 자체가 성립하지 않는다	카탈로그에 없는 피처는 요청 단계에서 거부된다
회원증 종류마다 열람·대출·기록 조회 권한이 다르다	역할마다 허용되는 행위가 다르다
대출대에 남는 기록 — 누가 언제 무엇을 빌렸는가	접근 로그 — 누가 언제 무슨 목적으로 조회했는가
개정판은 새 판으로 나오지 초판을 덮어쓰지 않는다	정의 변경은 새 버전으로 발행한다

비유가 깨지는 지점은 반납이다. 책은 빌려 가면 서가에서 사라지고 반납해야 돌아오지만, 피쳐 값은 조회되는 순간 복제되므로 회수라는 절차가 없다. 그래서 통제의 무게가 "빌려준 뒤 돌려받는 것"이 아니라 *****빌려주기 전에 판정하고, 그 판정을 남기는 것*****에 실린다.

3. 카탈로그 — 피쳐에 신원을 붙인다

8장의 피쳐 정의서에는 스키마(schema)와 소유자가 이미 들어 있었다. 거버넌스는 그 정의서를 한 팀의 데모에서 **여러 소비자가 공유하는 계약**으로 격상시키는 일이다. 정의만 있고 신원이 없으면, 그 값이 이상할 때 누구에게 물어야 하는지와 정의가 바뀔 때 누구에게 알려야 하는지를 아무도 모른다.

피쳐의 신원은 세 가지로 이루어진다. **정의**는 어떤 산식으로 계산되는가이고, **소유자**는 그 정의와 품질에 책임지는 부서이며, **사용 목적**은 이 피쳐가 무엇을 위해 존재하는가다. 소유자를 적어 두면 원천이 바뀌었을 때 소비자에게 알릴 의무가 어디에 붙는지가 정해진다. 사용 목적을 적어 두면 나중에 "이 조회가 등록된 목적 안에 있었는가"를 대조할 수 있고, 그 대조가 다음 절 접근 제어의 기준이 된다.

신원이 없을 때 무엇이 깨지는지는 8장이 이미 세 번 보여 줬다. 같은 피쳐를 훈련 쪽과 서빙 쪽이 각자 계산해 16·17·18이라는 세 값이 갈린 스큐(skew), 적재 창을 벗어나 조용히 비어 버린 온라인 스토어, 시점 조인에서 소리 없이 사라진 한 행이다. 세 사고의 공통 원인은 산식이 틀렸다는 것이 아니라 **"이 피쳐가 무엇이고 누가 보증하는가"가 어디에도 기록되지 않았다는 것**이다.

카탈로그는 이 위험을 문서가 아니라 구조로 누른다. 핵심은 카탈로그를 손으로 쓰지 않는 것이다. 실습은 8장 레지스트리(registry)에서 뽑아 둔 정의 파일을 읽어 카탈로그 행으로 옮긴다. 설명은 정의 칸으로, 자료형은 dtype 칸으로, 소유자와 개인정보 표기는 각각 제 칸으로 들어간다. 사람이 옮겨 적지 않으므로 문서와 실물이 어긋날 자리가 없다.

8장에 없던 칸이 하나 더 붙는다. **소비자** — 이 피쳐를 실제로 읽는 모델과 서비스의 목록이다. 실습 카탈로그에는 피쳐 2종이 등록된다. `complaint_count` (Int64)는 "전일 확정 민원 건수"이고 소비자가 셋이다 (9장 훈련, 10장 서빙, 14장 통합 MVP). `day_unmapped_rate` (Float64)는 "전일 정제 품질 — 매핑 실패율"이고 소비자가 하나다(`complaint_model_v1` 서비스).

이 한 칸이 두 가지 판정을 대신한다. 첫째는 변경 통보의 수신자다. 정의를 고칠 때 누구에게 알릴지를 추정하지 않고 목록에서 읽는다. 둘째는 폐기 가능 여부다. 원칙은 **소비자가 없는 피쳐만 안전하게 폐기한다**이며, `complaint_count` 는 소비자가 셋이므로 지금 없애면 세 소비자가 동시에 실패한다. 폐기하려면 먼저 셋을 다른 피쳐로 옮겨 목록을 비워야 한다. 카탈로그가 없으면 이 판정을 "아무도 안 쓸 것"이라는 추정으로 대체하게 되고, 그 추정이 틀리는 순간이 8장의 침묵 실패로 되돌아간다.

4. 접근 제어 — 인가와 기록은 다른 장치다

접근 통제가 성립하려면 두 장치가 함께 있어야 한다. **인가**는 "이 역할이 이 행위를 해도 되는가"를 사전에 판정하고, **사용 이력**은 "실제로 누가 언제 무엇을 했는가"를 사후에 답한다. 인가만 있고 이력이 없으면 감사에서 "누가 이 값을 봤는가"에 답할 수 없고, 이력만 있고 인가가 없으면 아무나 접근한 뒤 기록만

정확하게 남는다.

실습은 행위를 세 가지로 쪼갬다. `read_definition` 은 카탈로그의 메타 정보를 읽는 것이고, `read_value` 는 원시 피쳐 값을 조회하는 것이며, `read_log` 는 사용 이력을 열람하는 것이다. 이렇게 쪼개는 이유는 역할마다 필요한 범위가 다르기 때문이다. 훈련과 서빙은 값을 읽어야 하지만 남의 조회 이력을 볼 이유가 없고, 외부 감사자는 정의와 로그를 봐야 하지만 원시 값을 볼 이유가 없다. 감사는 값이 맞는지가 아니라 절차와 기록이 지켜졌는지를 보기 때문이다.

판정 엔진은 요청 하나를 세 관문에 차례로 통과시킨다. ① 이 역할이 정책에 등록되어 있는가, ② 이 피쳐가 카탈로그에 등록되어 있는가, ③ 이 역할에 이 행위 권한이 있는가. 순서가 곧 통제의 우선순위다. 행위 권한을 먼저 보면 카탈로그에 없는 피쳐에 대한 권한을 논하는 모순이 생긴다. 그리고 **기본값은 거부**다. 허용은 세 관문을 모두 통과한 경우뿐이다.

실습은 접근 요청 12건을 이 엔진으로 판정해 **허용 8건, 거부 4건**을 얻고, 허용과 거부를 가리지 않고 전부 로그에 적재한다. 거부 4건은 건수가 아니라 종류가 요점이다. 네 건이 각각 다른 관문에 걸린다.

표 13.1 접근 거부 4건과 드러나는 통제 지점(실측)

요청(역할 · 피쳐 · 행위)	거부 사유	드러나는 통제
analyst · complaint_count · read_log	로그 열람은 감사 권한 필요	행위 단위 권한 분리
external_auditor · complaint_count · read_value	감사 역할은 원시 값 조회 불가	목적에 따른 범위 제한
marketing_bot · complaint_count · read_value	미등록 역할 — 정책에 없음	기본 거부
analyst · resident_arrears · read_value	카탈로그 미등록 피쳐	카탈로그 게이트(gate)

둘째 행에서 값이 존재하는데도 거부된다는 점을 눈여겨본다. 목적에 따른 제한은 "값이 없어서"가 아니라 "조회할 근거가 없어서" 막는다. 넷째 행의 `resident_arrears` 는 가구 단위 체납 같은 민감한 피쳐를 가정한 이름인데, 카탈로그에 없으므로 값이 있는지 없는지 따지기 전에 요청 자체가 거부된다. **접근의 전제가 등록**이라는 뜻이고, 그래야 카탈로그 밖에서 몰래 만들어 쓰는 피쳐(shadow feature)가 통제를 우회하지 못한다.

로그에는 판정 결과만이 아니라 **목적**이 함께 남는다. `analyst` 역할은 같은 `complaint_count` 를 "지역별 민원 추이 분석" 목적으로 정의를 읽을 때도 허용되고 "월간 민원 리포트" 목적으로 값을 읽을 때도 허용되지만, "동료 조회 이력 확인" 목적으로 로그를 읽으려 할 때는 거부된다. 판정 자체는 행위 권한으로 내려지고 목적은 기록으로 남는데, 이 기록이 있어야 사후에 "그 조회가 등록된 사용 목적 안에 있었는가"를 대조할 수 있다. 목적을 남기지 않으면 로그는 "누가 봤다"까지만 말하고 "왜 봤다"에는 침묵한다.

로그만 있고 차단이 없는 시스템이 어떻게 실패하는지도 이 12건에 들어 있다. 기본값을 허용으로 두었다면 `marketing_bot` 의 요청은 통과하고, 그 사실은 로그에 "허용"으로 정확하게 남는다. 사고를 막지 못한 채 사고의 경위만 잘 기록한 상태다. 기본값이 거부여야 하는 이유는 정책을 촘촘히 쓰기 위해서가 아니라, **정책을 다 못 썼을 때 안전한 쪽으로 실패하기 위해서**다.

실습 피쳐 두 종은 지역 단위 집계라 개인정보를 담지 않는다. 그러나 피쳐가 개인이나 가구 단위 정보를 담는 순간 목적 밖 이용은 법이 직접 제한하고, 접근 권한 부여와 접속기록 보관도 법이 요구하는 안전조치가 된다. 근거 조문과 그 예외는 16장에서 다룬다.

마지막으로, 이 판정과 기록이 제대로 돌아갔는지를 **사람이 눈으로 확인하지 않는다**. 실습은 접근 로그·카탈로그·품질 결과·변경 이력에서 10개 항목의 감사 점검표를 자동 생성하고, 실측은 10항목 전부 통과다. 항목마다 근거로 삼는 기록이 다르다. 1·2번은 로그가 빠짐없이 남았는지, 3~5번은 판정이 정책과 일치하는지, 6·7번은 카탈로그 메타가 다 채워졌는지, 8번은 품질, 9·10번은 변경 이력을 본다. 자동 생성의 요점은 사람이 "지켰습니다"라고 주장할 자리가 없다는 것이다.

5. 품질 게이트 — 계약 위반은 경보가 아니라 차단이다

11장에서 본 드리프트(drift) 감시는 값의 분포가 시간이 지나며 이동하는지를 본다. 이 장의 품질 점검은 층이 다르다. 개별 값이 **계약을 어겼는가**를 배포와 서빙 앞에서 막는 게이트다. 드리프트 경보는 "원인을 확인해 보자"는 신호여서 계절 변동으로 밝혀지면 넘어갈 수 있지만, 품질 위반은 "이 값은 애초에 틀렸으니 쓰면 안 된다"는 차단이라 해석의 여지가 없다.

둘을 한 층으로 뭉치면 양쪽으로 실패한다. 정상적인 계절 변동을 데이터 오류로 오인해 파이프라인을 세우거나, 반대로 명백한 결측을 분포 감시가 그냥 넘긴다.

실습은 8장 실데이터 9행(3일 × 3지역)에 세 규칙을 적용하고, 규칙 이름을 공공데이터 품질관리의 세 지표에 맞춘다. 결측이 없는지 보는 규칙이 완전성, 건수가 0 이상이고 실패율이 0과 1 사이인지 보는 규칙이 정확성, (지역코드, 이벤트 시각) 키가 중복되지 않는지 보는 규칙이 일관성이다. 실측은 세 규칙 모두 9/9 통과다.

통과했다는 사실보다 **각 규칙이 서로 다른 사고를 담당한다**는 점이 중요하다. 정제 과정의 버그로 강남구 행이 두 번 적재되면 키 유일성 규칙이 막는다. 이 규칙이 없으면 시점 조인에서 같은 키에 두 값이 붙어 그 지역의 훈련 가중치가 조용히 두 배가 된다. 실패율이 계산 오류로 1.2가 되면 범위 규칙이, 건수가 누락되어 비면 결측 규칙이 각각 다른 실패를 막는다. 어느 하나만 빠져도 그 유형의 사고는 그대로 통과한다.

이 세 규칙은 임계값이 전부 0이라 고를 것이 없어 보인다. 게으름이 아니라 규칙의 성격이다. 결측·중복·범위 이탈은 정도의 문제가 아니라 위반이나 아니냐의 문제라서, 허용 건수를 한 건이라도 열면 "몇 건까지 괜찮은가"라는 답 없는 협상이 시작된다.

그런데 규칙을 하나만 더 붙이면 곧바로 고를 값이 생긴다. "매핑 실패율이 X를 넘으면 배포를 막는다"에서 X는 0이 될 수 없다. 실패율 0을 요구하면 원천의 코드 체계가 바뀌는 날마다 배포가 멈춘다. 그러면 X를 무엇에서 정하는가. 관례가 아니라 **하루가 건널 수 있는 오차에서 역산한다**. 매핑 실패는 그 지역 민원이 집계에서 빠진다는 뜻이므로, 물어야 할 질문은 "인력 배치 결과가 바뀌지 않는 오차가 몇 %인가"이고, 답할 사람은 데이터 담당자가 아니라 배치를 결정하는 부서다. 그래서 임계값 결정은 3절에서 정한 소유자의 책임 범위에 들어간다.

역산 없이 관례로 고르면 무엇을 모르게 되는지는 실측 3일치에 대 보면 드러난다. `day_unmapped_rate`의 현행 값은 0.05, 0.0588, 0.0455다. 상한을 6%로 두면 사흘 다 통과하고, 5%로 두면 2026-07-02 하루가 걸리며, 4.5%로 두면 사흘이 전부 걸린다. **1.5%포인트 차이가 "한 번도 안 걸림"과 "매일 걸림"을 가른다.** 이 민감도를 모른 채 5%를 고르면 게이트는 매일 울려 무시당하거나 한 번도 울리지 않아 없는 것과 같아진다.

6. 변경 관리 — 정의를 덮어쓰면 과거가 다시 쓰인다

피쳐 정의는 고정된 것이 아니다. 정제 규칙이 바뀌면 같은 이름의 피쳐가 다른 값을 갖는다. 이때 정의를 조용히 덮어쓰면 과거에 기록된 값과 지금 기록되는 값의 의미가 갈리고, 그 피쳐로 훈련된 모델은 어느 정의로 배웠는지 모르는 채 다른 정의의 값으로 서빙받는다. 8장에서 본 훈련-서빙 스큐가 산식 개정이라는 다른 경로로 되돌아오는 것이다.

그래서 규율이 둘이다. **변경은 덮어쓰기가 아니라 새 버전 발행이고, 변경 전에 영향 소비자를 식별한다.**

실습은 `day_unmapped_rate`의 산식 변경을 실제 데이터로 계산해 본다. 현행 정의 v1은 미매핑 건수를 유효 건수로 나누고, 제안 정의 v2는 물리 건수로 나눈다. 7장 집계에서 중복 제거가 있었던 날만 유효 건수와 물리 건수가 같으므로, 값이 바뀌는 날도 그날뿐이다. 2026-07-01은 유효 20·물리 20이라 두 정의 모두 0.05이고, 2026-07-03은 유효 22·물리 22라 두 정의 모두 0.0455다. 2026-07-02만 유효 17·물리 18로 갈려 **0.0588이 0.0556으로 바뀐다.** 하루가 바뀌고, 그날의 세 지역 행이 영향을 받아 9행 중 3행이 달라진다.

여기서 확인할 것은 값의 크기가 아니라 절차다. 영향 소비자는 담당자의 기억이 아니라 카탈로그의 소비자 칸에서 나온다. `day_unmapped_rate`의 소비자는 `complaint_model_v1` 서비스 하나이므로 통보 대상도 하나로 확정된다. 실습은 이 변경을 요청자·승인자·사유·영향 소비자·영향 행 수와 함께 변경 이력에 적재한다. 다섯 항목이 다 있어야 감사에서 "누가 왜 바꿨고 누가 승인했으며 무엇이 영향받았는가"에 기록으로 답한다.

통보를 어디까지 보낼지도 설계 결정이다. 소비자를 서비스 단위로 적으면 실제로 그 필드를 안 쓰는 소비자에게도 통보가 가고, 필드 단위로 적으면 정확해지는 대신 값의 흐름을 추적하는 별도 도구가 필요하다. 두 오류의 대가가 비대칭이라 선택은 정해진다. 안 쓰는 소비자에게 알리면 그 부서가 한 번 확인하고 끝이지만, 쓰는 소비자를 빠뜨리면 그 모델은 바뀐 정의를 모른 채 계속 돌고 그 사실은 지표가 튼 뒤에야 드러난다. 넓게 알리고 좁게 확인하는 쪽이 맞다. 다만 넓은 통보를 반복하면 수신 부서가 무시하게 되므로, 통보문에 영향 행 수와 영향 소비자를 실어 받는 쪽이 자기 일인지 즉시 판단하게 만든다.

7. 실습 13.1 피쳐 거버넌스 설계와 구현

실습 목표

8장 정의와 7장 집계를 입력으로 카탈로그를 만들고, 접근 요청 12건을 정책으로 판정해 로그에 남기며, 품질 규칙 3종과 정의 변경 하나를 적용해 감사 점검표까지 자동 생성한다. 남이 정해 준 정책으로 코드부터 돌리면 왜 기본값이 거부인지, 왜 임계값이 0인지 묻지 않게 되므로 **실행 전에 자기 정책을 먼저 적고**

판정을 예측한다.

1단계 설계 — 실행 전에 채운다

가상 발주 조건은 이렇다. 기관 피처 플랫폼에 여러 부서가 피처를 올리는데 지역 단위 집계와 가구 단위 체납 피처가 섞여 있고, 외부 감사자가 반기 1회 접근 기록을 열람하되 감사 대상은 절차와 기록이지 값이 아니다. 매핑에 실패해 빠진 민원은 그 지역의 인력 배치 산정을 낮추므로 품질 위반이 서빙까지 흘러가면 안 된다. 본문의 표 13.1과 5절의 임계값은 예시 답안이므로 채운 뒤에 비교한다.

표 13.2 설계 워크시트 — 학습자 작성용

항목	내가 정한 값	근거(요구 조건의 어느 문장에서 나왔는가)
외부 감사 역할에 허용할 행위		
정책에 없는 역할의 기본 판정		
카탈로그에 없는 피처 요청의 판정		
매핑 실패율 상한(배포 차단 기준)		
이 설계가 깨지는 조건		

근거 칸에 "기본값이라서"를 쓰지 않는다. 실패율 상한은 5절대로 하류가 견딜 오차에서 역산하고, 마지막 행에는 자기 선택이 불리해지는 상황을 적는다.

이어서 실행 **전에** 세 가지를 예측하고 각각 한 줄 근거를 붙인다. 요청 12건 중 거부가 몇 건일지, 그 거부가 드러내는 통제 지점이 몇 **종류**일지, 자기가 정한 실패율 상한에 3일 중 며칠이 걸릴지다. 둘째 항목은 건수가 아니라 종류를 세는 칸이다. 같은 사유로 거부된 요청이 열 건이어도 통제 지점은 하나다.

2단계 실행

Python 3.10 이상이면 되고 외부 인프라는 필요 없다. 카탈로그와 로그는 SQLite에, 나머지는 표준 라이브러리로 처리한다.

```
cd practice/chapter13
python3 -m venv venv && source venv/bin/activate
pip install -r code/requirements.txt # 외부 의존성 없음
python run_chapter13.py
```

판정 엔진의 세 관문이 코드에서는 조건문 세 줄이다. 순서가 곧 통제의 우선순위라는 4절의 설명이 그대로 보인다.

```

if role not in ACCESS_POLICY:          decision, reason = "DENY", "미등록 역할"
elif feature not in catalog_names:      decision, reason = "DENY", "카탈로그 미등록 피처"
elif action not in ACCESS_POLICY[role]: decision, reason = "DENY", "권한 없음(목적 제한)"
else:                                   decision, reason = "ALLOW", "정책 허용"

```

전체 코드는 [practice/chapter13/code/13-1-feature-catalog.py](#) 참고

실행 결과 확인 사항

산출물은 `practice/chapter13/data/output/ch13_governance_report.json` 이다.

1. **카탈로그**: 피처 2종(`complaint_count` · `day_unmapped_rate`)이 소유자·개인정보 표기·소비자와 함께 등록되었는가
2. **접근 판정**: 요청 12건 중 허용 8건·거부 4건이고, 거부 4건의 사유가 서로 다른가(표 13.1)
3. **품질**: 세 규칙이 모두 9/9 통과인가
4. **변경 관리**: 2026-07-02만 값이 바뀌고(0.0588 → 0.0556) 영향 행이 3개인가
5. **감사 점검표**: 10항목 전항 통과이고 마지막 줄이 `CH13_RUN_PASS` 인가
6. **재현성**: 다시 실행해도 증거 JSON이 바이트 단위로 같은가

3단계 대조

예측한 값과 실측을 맞춰 본다. 실측은 12건 중 거부 4건이고, 그 넷이 걸린 관문은 네 종류 전부 다르다.

거부 건수는 맞았는데 통제 지점 수를 적게 적었다면, 정책의 강도를 건수로 재고 있었던 것이다. 정책의 강도는 몇 건을 막았는지가 아니라 **서로 다른 이유로 막을 수 있는 관문이 몇 개인지**로 정해진다. 관문이 셋뿐인 정책은 거부 건수가 같아도 네 번째 유형의 요청을 통과시킨다.

기본 판정을 허용으로 적었다면 `marketing_bot`의 요청이 통과하고 그 사실이 로그에 "허용"으로 남는다는 점을 확인한다. 실패율 상한에 "1일"을 예측하고 근거로 "5%가 관례라서"를 적었다면, 값을 고른 것이 아니라 관례를 옮겨 적은 것이다. 6%면 0일, 4.5%면 사흘 전부라는 폭을 확인한 뒤 표 13.2의 마지막 행을 다시 쓴다.

8. 핵심 요약

1. **카탈로그의 소비자 칸이 통보 대상과 폐기 가능 여부를 동시에 정한다.** 실습 카탈로그에서 `complaint_count`는 소비자가 셋(9장 훈련·10장 서빙·14장 통합)이라 지금 폐기하면 셋이 동시에 실패하고, `day_unmapped_rate`는 소비자가 하나라 통보 대상도 하나로 확정된다. 이 칸이 없으면 두 판정을 모두 추정으로 대체하게 된다.

2. 인가와 기록은 어느 한쪽만으로는 통제가 되지 않는다. 인가만 있으면 "누가 봤는가"에 답하지 못하고, 기록만 있으면 사고를 막지 못한 채 경위만 정확히 남는다. 실습이 허용 8건과 거부 4건을 같은 무게로 로그에 남기는 이유가 이것이다.

3. 기본값은 거부이며, 접근의 전제는 등록이다. 거부 4건은 각각 행위 분리·범위 제한·기본 거부·카탈로그 게이트에 걸렸다. 특히 카탈로그에 없는 `resident_arrears` 는 값의 존재 여부를 따지기 전에 요청이 거부되므로, 등록 밖에서 만든 피처가 통제를 우회하지 못한다.

4. 품질 위반은 차단이고 드리프트는 경보다. 층이 다른 두 판정을 뭉치면 계절 변동을 오류로 막거나 결측을 그냥 넘긴다. 그리고 임계값은 관례가 아니라 하류가 견딜 오차에서 역산한다 — 실측 3일치에서 상한 6%는 하루도 막지 않고, 5%는 하루, 4.5%는 사흘 전부를 막는다.

5. 정의 변경은 버전으로 내고 영향 소비자를 먼저 식별한다. v1에서 v2로 산식을 바꾸면 2026-07-02 하루만 0.0588에서 0.0556으로 바뀌지만, 그 하루가 9행 중 3행이고 영향 소비자는 카탈로그에서 자동으로 나온다. 요청자·승인자·사유·영향 소비자·영향 행 수를 함께 남겨야 감사에서 기록으로 답한다.

9. 과제

실습을 실행해 생성된 `practice/chapter13/data/output/ch13_governance_report.json` 을 그대로 LMS에 업로드하고, 표 13.2(3단계 대조를 반영한 최종본)를 함께 제출한다. 이어서 자기 산출물의 `access_control` 을 근거로 세 가지를 답한다.

1. `allow` 와 `deny` 건수를 적고, 거부된 요청 전부의 역할·피처·목적·사유를 표로 옮긴다.
2. 각 거부가 어떤 통제 원리에 걸린 것인지 하나씩 짚는다(행위 분리, 목적에 따른 범위 제한, 기본 거부, 카탈로그 게이트).
3. 접근을 기록만 하고 차단하지 않는 시스템에서 생길 수 있는 사고를 하나, 자기 로그의 요청 한 건을 인용해 세 문장 이내로 서술한다.

수업일 포함 7일 이내에 제출한다.

10. 더 알아보기

이 장에서 다루지 않은 내용은 실무교재 `docs/chapter13.md` 에 있다.

- 접근 등급 체계(4단계)와 등급 수를 정하는 기준 — 공개 집계부터 민감정보까지의 통제 설계:
`docs/chapter13.md` §13.3
- 개인정보 관련 법령과 안전조치 기준의 조문 대조 — 목적 외 이용 제한, 접근 권한 관리, 접속기록 보관:
§13.1-§13.3 (본격적인 논의는 16장)
- 카탈로그·계보 도구와 민간 데이터 플랫폼의 같은 장치 — 도구 이름, 민간 지표, 역방향 적용:
§13.2-§13.3-§13.4

- **데이터 계약 명세와 스키마 레지스트리** — 계약을 기계가 읽는 파일로 두고 호환성을 등록 시점에 검사하는 방식: §13.4